

HealthGuard AI

Medical Device Cybersecurity Risk Assessment

Assessment 1
2026-08-08 17:59:59

CYBERSECURITY DECISION-SUPPORT REPORT

EDUCATIONAL PROTOTYPE

DEVICE PROFILE

DEVICE

Legacy Remote Medical
Server

DEVICE TYPE

Medical Server

MANUFACTURER

IBM Test

MODEL

Test

OPERATING SYSTEM

Windows Server

SUPPORT STATUS

Unknown

DEPARTMENT

IT

CVE SEARCH

Apache Log4j

OVERALL CYBERSECURITY RISK

71/100

HIGH RISK

01 Key Security Findings

The support status of the operating system is unknown.

The device has direct or indirect internet access.

Vendor remote access is enabled.

The network-connected device is not isolated in a dedicated segment.

Network communications are not confirmed to be encrypted.

Security audit logging is unavailable or disabled.

No formal security patch process was identified.

Endpoint protection is not supported or available.

No backup or recovery process was identified.

02 Recommended Controls

1

Confirm software lifecycle and support status with the manufacturer.

2

Remove unnecessary internet access and restrict communications.

3

Restrict vendor access to approved accounts, times, and sources.

4

Place the device in a dedicated medical-device VLAN.

5

Use secure and encrypted communication protocols where supported.

6

Enable logging and forward security events to a protected system.

7

Create a vendor-coordinated patch and vulnerability-management process.

8

Use network monitoring and other compensating security controls.

9

Document backup, recovery, and clinical downtime procedures.

03

Existing Positive Controls

Vendor remote access uses multifactor authentication.

The device supports unique user accounts.

Default credentials have been changed.

04

Vulnerability & Exploitation Intelligence

NVD keyword matches are candidate vulnerabilities and do not confirm product or version applicability.

10

CVE CANDIDATES

4

CRITICAL

2

HIGH

2

CISA KEV MATCHES

CVE	CVSS	SEVERITY	ASSESSMENT CONTEXT	EXPLOITATION
CVE-2022-23305	9.8	CRITICAL	By design, the JDBCAppender in Log4j 1.2.x accepts an SQL statement as a configuration parameter where the values to be inserted are converters from PatternLayout. The message converter, %m, is likely to always be included. This allows attackers to manipulate the SQL by entering crafted strings into input fields or headers of an ...	NO KEV MATCH
CVE-2022-23302	8.8	HIGH	JMSSink in all versions of Log4j 1.x is vulnerable to deserialization of untrusted data when the attacker has write access to the Log4j configuration or if the configuration references an LDAP service the attacker has access to. The attacker can provide a TopicConnectionFactoryBindingName configuration causing JMSSink to perform ...	NO KEV MATCH
CVE-2021-44832	6.6	MEDIUM	Apache Log4j2 versions 2.0-beta7 through 2.17.0 (excluding security fix releases 2.3.2 and 2.12.4) are vulnerable to a remote code execution (RCE) attack when a configuration uses a JDBC Appender with a JNDI LDAP data source URI when an attacker has control of the target LDAP server. This issue is fixed by limiting JNDI data sou ...	NO KEV MATCH
CVE-2021-45105	5.9	MEDIUM	Apache Log4j2 versions 2.0-alpha1 through 2.16.0 (excluding 2.12.3 and 2.3.1) did not protect from uncontrolled recursion from self-referential lookups. This allows an attacker with control over Thread Context Map data to cause a denial of service when a crafted string is interpreted. This issue was fixed in Log4j 2.17.0, 2.12.3 ...	NO KEV MATCH
CVE-2021-45046	9.0	CRITICAL	It was found that the fix to address CVE-2021-44228 in Apache Log4j 2.15.0 was incomplete in certain non-default configurations. This could allows attackers with control over Thread Context Map (MDC) input data when the logging configuration uses a non-default Pattern Layout with either a Context Lookup (for example, \$\$ {ctx:logi ...	KEV MATCH Apache / Log4j2 Ransomware: Known Required Action Apply updates per vendor instructions.
CVE-2021-4104	7.5	HIGH	JMSAppender in Log4j 1.2 is vulnerable to deserialization of untrusted data when the attacker has write access to the Log4j configuration. The attacker can provide TopicBindingName and TopicConnectionFactoryBindingName configurations causing JMSAppender to perform JNDI requests that result in remote code execution in a similar f ...	NO KEV MATCH

CVE	CVSS	SEVERITY	ASSESSMENT CONTEXT	EXPLOITATION
CVE-2021-44228	10.0	CRITICAL	Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrar ...	KEV MATCH Apache / Log4j2 Ransomware: Known Required Action For all affected software assets for which updates exist, the only acceptable remediation actions are: 1) Apply updates; OR 2) remove affected assets from agency networks. Temporar ...
CVE-2020-9488	3.7	LOW	Improper validation of certificate with host mismatch in Apache Log4j SMTP appender. This could allow an SMTPS connection to be intercepted by a man-in-the-middle attack which could leak any log messages sent through that appender. Fixed in Apache Log4j 2.12.3 and 2.13.1	NO KEV MATCH
CVE-2017-5645	9.8	CRITICAL	In Apache Log4j 2.x before 2.8.2, when using the TCP socket server or UDP socket server to receive serialized log events from another application, a specially crafted binary payload can be sent that, when deserialized, can execute arbitrary code.	NO KEV MATCH
CVE-2012-5616	1.5	LOW	Apache CloudStack 4.0.0-incubating and Citrix CloudPlatform (formerly Citrix CloudStack) before 3.0.6 stores sensitive information in the log4j.conf log file, which allows local users to obtain (1) the SSH private key as recorded by the createSSHKeyPair API, (2) the password of an added host as recorded by the AddHost API, or th ...	NO KEV MATCH

05

MITRE ATT&CK Context

Technique mappings describe potentially relevant adversary behavior associated with identified security conditions. They do not indicate observed malicious activity.

T1133**External Remote Services****Initial Access / Persistence**

Externally accessible vendor remote services can provide a pathway into internal systems if compromised or misused.

T1021**Remote Services****Lateral Movement**

Remote administration services may be abused to access systems or move between systems when credentials are available.

T1190**Exploit Public-Facing Application****Initial Access**

Internet-accessible services may expose exploitable software or management interfaces to external adversaries.

AI-Assisted Security Analysis

Generated as decision-support commentary after deterministic risk scoring. The AI does not modify the calculated score.

Executive Summary

The application assigned this device a score of 71 (High) based on the supplied device details and the application-generated findings. Key contributors to the high score include unknown operating-system support status, direct or indirect internet access, enabled vendor remote access, lack of network isolation, unconfirmed encryption of communications, disabled or unavailable security audit logging, absence of a formal patch process, lack of endpoint protection, and no identified backup/recovery process. Positive controls noted are vendor remote access with multifactor authentication, support for unique user accounts, and changed default credentials.

This assessment is educational decision support only and is not a compliance certification.

Primary Cybersecurity Risks

- Internet exposure and vendor remote access: The device has internet access and vendor remote access enabled. Even though MFA is used for vendor access (confirmed), external exposure and third-party connections increase attack surface and risk of unauthorized access.
- Unknown software lifecycle and lack of patch process: Support status of the operating system is unknown and no formal patch/vulnerability-management process was identified, increasing the likelihood of unpatched vulnerabilities.
- Lack of network isolation and unconfirmed encryption: The device is not confirmed to be on a dedicated medical-device segment and communications encryption is not confirmed, increasing risk of lateral movement and eavesdropping.
- Missing logging and endpoint protection: Security audit logging is unavailable or disabled and endpoint protection is not supported/available, reducing detection capability and increasing the risk that compromises go unnoticed.
- No backup/recovery: No backup or recovery process was identified, heightening operational risk if the server is lost or corrupted.

Patient-Safety and Operational Considerations

- Potential impacts include loss of service, degraded availability of functions provided by the server, and prolonged recovery time if the device is compromised or fails.
- Any changes (network isolation, service interruptions, or vendor access restrictions) must be coordinated with biomedical engineering, clinical leadership, and other stakeholders to preserve patient-care continuity and scheduled workflows.
- Because the device is identified as a medical server, operational availability and validated recovery procedures should be considered part of patient-safety planning.

HIPAA Security Considerations

- Confirmed: the supplied data indicates the device does not store PHI (stores_phi: false). Even so, technical safeguards such as access controls, encryption of communications, logging, and vendor access controls remain relevant to information-security obligations and to protecting systems that may interact with PHI.
- Relevant gaps from the findings include lack of confirmed encryption, disabled/unavailable audit logging, absence of a patch process, and vendor remote access controls beyond MFA (MFA is present).
- This assessment provides security considerations only. It is not a HIPAA compliance determination or legal opinion.

Immediate Priority Actions (top 3–5, prioritized)

1. Confirm software lifecycle/support status with the manufacturer (highest priority)
 - Obtain vendor confirmation of the exact OS version and support status to determine patchability and end-of-support timelines.
 - If the OS is unsupported or cannot be patched, begin remediation planning immediately.
2. Restrict and control internet and vendor access
 - Remove unnecessary internet access and restrict inbound/outbound communications to required destinations and ports.
 - Restrict vendor remote access to approved accounts, time windows, and source IPs; retain MFA (confirmed) and implement just-in-time or jump-host access where possible.
 - Coordinate implementation with biomedical engineering and clinical leadership before blocking or altering remote vendor connections.
3. Verify and implement network segmentation and encryption
 - Place the device in a dedicated medical-device VLAN or segment to reduce lateral movement risk—coordinate with clinical/biomed before making changes that could affect availability.
 - Verify and enable secure, encrypted communication protocols for all supported services.
4. Enable logging and forward security events
 - Enable security audit logging on the device and forward logs to a protected log-aggregation/SEIM system for monitoring and retention.
5. Establish backup and recovery procedures
 - Document and implement backups, recovery procedures, and clinical downtime plans. Test recovery to confirm integrity and acceptable RTO/RPO.

Note: Do not disconnect or isolate a clinical device without consultation with biomedical engineering, clinical leadership, and consideration of patient-care continuity.

Long-Term Recommendations

- Create and document a vendor-coordinated patch and vulnerability-management process, including testing and timelines for critical fixes.
- Procure or enable endpoint protection suitable for the server OS and integrate alerts into monitoring workflows.
- Implement continuous network monitoring and intrusion-detection capabilities on the medical-device VLAN and across critical segments.
- Maintain an inventory and lifecycle plan for the device (including exact OS version, supported software components, and end-of-support dates).
- Establish contractual controls with the vendor covering access auditing, change control, and documented support SLAs.
- Periodically review and test incident response, business continuity, and disaster-recovery procedures specific to this device and its services.

Limitations and Assumptions

- Confirmed information used:
 - Device name: Legacy Remote Medical Server; manufacturer: IBM Test; model: Test; device type: Medical Server; department: IT.
 - Operating system: Windows Server (no specific version provided).
 - Network-connected: true; internet_access: true; wireless_enabled: false.
 - Stores_phi: false.
 - Vendor remote access: true; remote_access_mfa: true (positive control).
 - Device supports unique user accounts and default credentials have been changed (positive controls).

- Application-calculated score: 71, Level: High; findings and recommendations listed in the supplied application output.
- Unknown or missing details:
 - Exact OS version and vendor support lifecycle (support_status: unknown).
 - Specific network topology, firewall rules, and whether communications are currently encrypted (communications encryption is listed as not confirmed).
 - Whether endpoint protection can be installed or is supported by vendor/software (finding states not supported or available).
 - Exact backup mechanisms, retention, and recovery testing (no backup/recovery process identified).
- This assessment is based solely on the supplied device information and the application-generated findings; no on-site inspection, active testing, packet captures, or vendor logs were reviewed. The application-calculated score and risk level were not changed by this assessment.

Final note: This document is educational decision support only and is not a compliance certification.

07

Report Limitations

HealthGuard AI is an educational cybersecurity decision-support prototype. This report is not a vulnerability scan, penetration test, clinical recommendation, legal opinion, regulatory audit, FDA determination, or HIPAA compliance certification. Findings should be independently reviewed by qualified cybersecurity, biomedical engineering, privacy, compliance, and clinical personnel before operational use.